ใบงานครั้งที่ 1 วางแผนก่อนทดสอบ

ส่วน B งานกลุ่ม (20 คะแนน)

ชื่อทีม	ScamGuard	ชื่อโครงงาน	Scam Image Detection Application

ข้อกำหนด

ใช้โครงงาน ENGSE212 ของทีมเท่านั้น ห้ามใช้ Case X

ถ้าวาดภาพส่วนประกอบจากโค้ดที่เขียนไปแล้ว ต้องติดป้าย “สร้างย้อนหลัง” ไม่หักคะแนน แต่ติดป้ายไม่ตรงความจริงได้ 0 ในขั้นนั้น

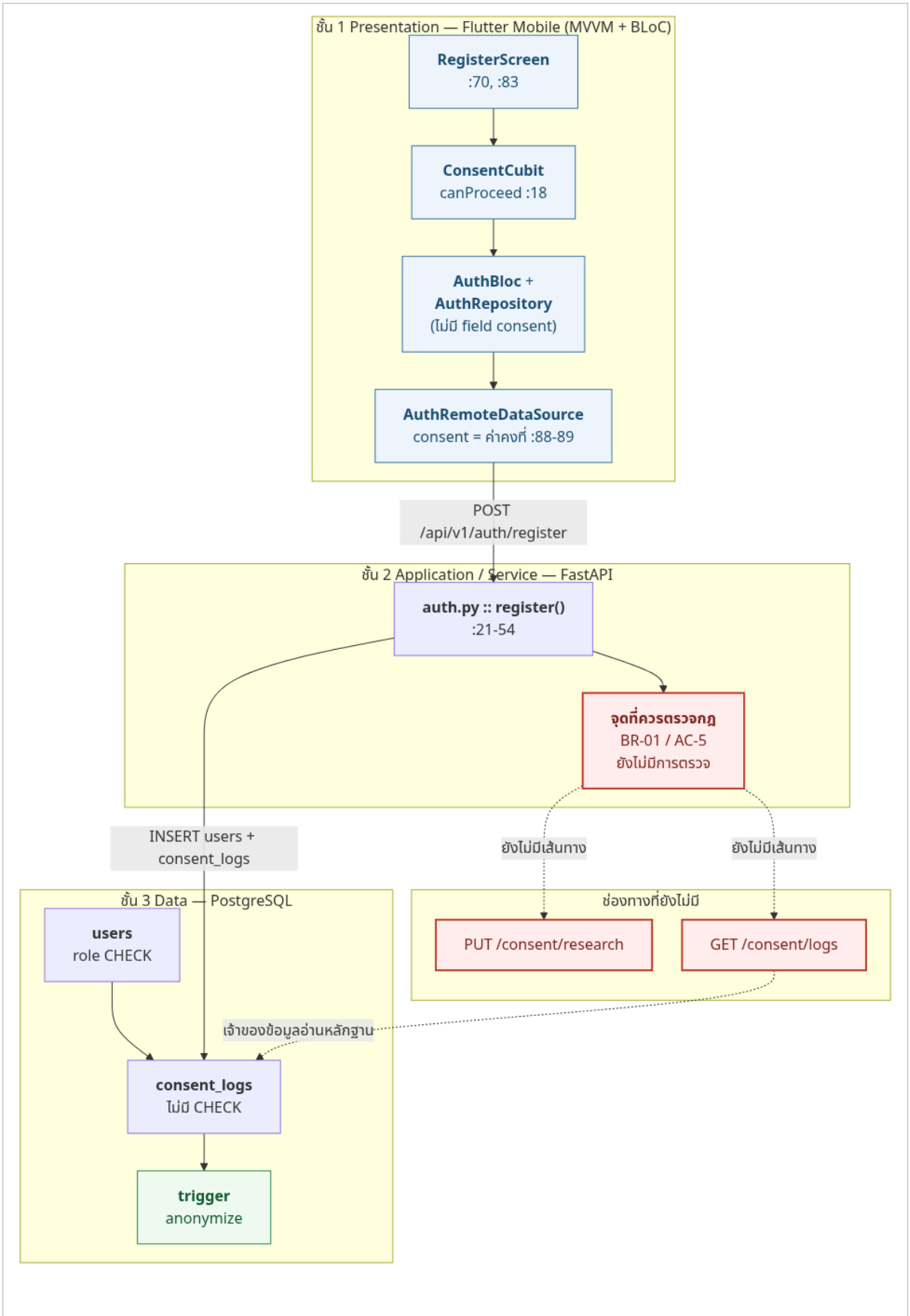
ถ้าตรวจแล้วไม่พบปัญหา ไม่ต้องแต่งข้อค้นพบ ให้แสดงหลักฐานว่าตรวจแล้วแทน ได้คะแนนเต็มเท่ากัน

ขั้นที่ 1 เลือก feature และกฎที่สำคัญที่สุดของ feature นั้น (2 คะแนน)

feature	การสมัครสมาชิกและการจัดการความยินยอม 2 ระดับ (System Consent + Research Consent) ครอบคลุม FR-AUTH-01 และ FR-PDPA-01
กฎที่สำคัญที่สุด	BR-01 (ฝังใน schema): "สมัครต้องมี consent row; หลักฐาน consent ต้องรอดพ้นการลบ user (ตัด link + ล้าง PII แทนการลบ)" ร่วมด้วยเงื่อนไขบังคับของ FR-AUTH-01 AC-5: ถ้า System Consent = false ระบบต้องตอบ HTTP 400 "System consent is required" และไม่สร้างผู้ใช้

พบกฎนี้ที่ไหน	เอกสาร: design/database.md:41 (BR-01) และ SRS v1.1 05_Software_Requirement_Specification.md:78-81 (FR-AUTH-01 AC-5), :565-596 (FR-PDPA-01 AC-1..AC-5) ไฟล์โค้ด: server/app/api/v1/auth.py:21-54 (register), server/app/schemas/auth.py:3-8 (RegisterRequest), server/app/models/consent.py:5-15 (ConsentLog), server/migrations/versions/d4e5f6a7b8c9_design_review_fixes.py:65-70 (FK SET NULL), server/migrations/versions/b7c8d9e0f1a2_anonymize_consent_on_user_delete.py:28-46 (trigger), scam_image_mobile/lib/features/auth/data/datasources/auth_remote_datasource.dart:76-91
ทำไมเลือกข้อนี้	1) เป็นประตูแรกที่ผู้ใช้ทุกคนผ่าน ถ้ากฎนี้ไม่ถูกบังคับ ทุกอย่างที่เกิดต่อไป (การเก็บภาพ การคำนวณคะแนน การนำข้อมูลไปใช้วิจัย) จะอยู่บนพื้นฐานที่ผิด 2) เป็นข้อกำหนดทางกฎหมาย PDPA ที่ PROJECT.md ระบุเป็น Critical context (C-04) และเป็นเงื่อนไขข้อมูลที่ห้ามเผยแพร่ 3) มีหลักฐานจริงอยู่แล้วว่าโค้ดไม่ทำตามกฎ (W05-F04/F05/F06) จึงพิสูจน์ได้โดยไม่ต้องเดา และเป็นตัวอย่างของปัญหาที่พบบ่อยที่สุด: กฎถูกบังคับที่หน้าจอแทนที่จะบังคับที่ชั้นบริการ

ขั้นที่ 2 วาดส่วนประกอบที่ feature นี้ผ่าน บอกชั้นของแต่ละส่วน ทางเดินข้อมูล และส่วนประกอบที่ตรวจกฎ (วาดมือแล้วแนบรูปได้) **(3 คะแนน)**

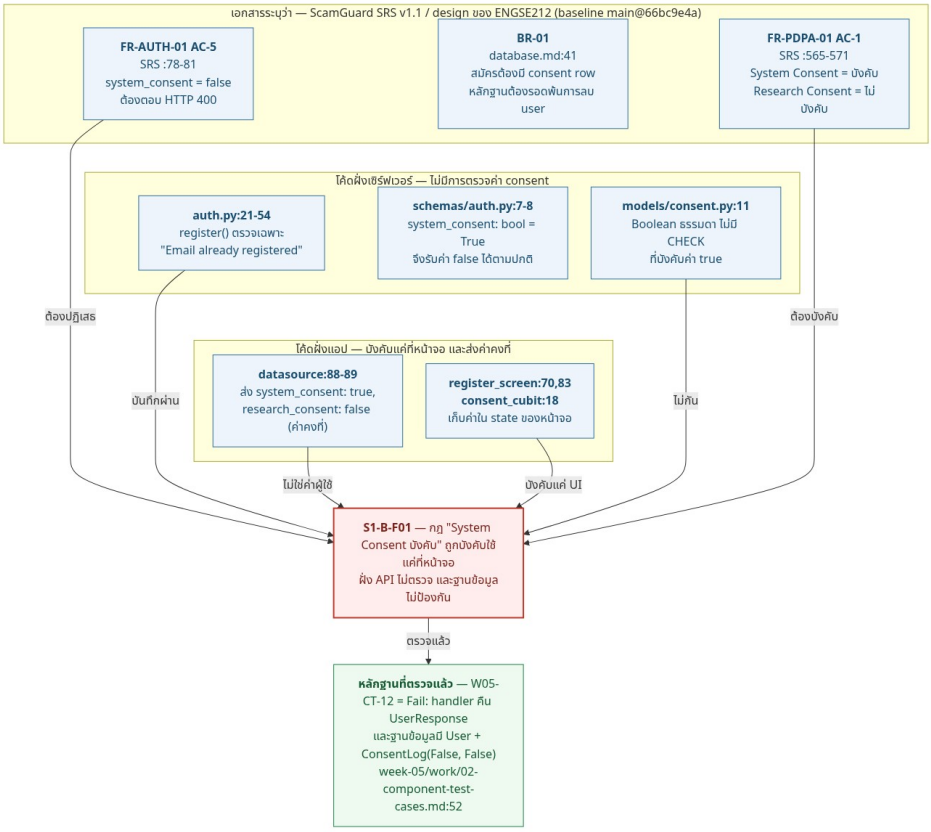


ที่มาของภาพ	สร้างย้อนหลัง: วาดเมื่อ 28-09-2026 จากไฟล์ server/app/api/v1/auth.py, server/app/models/consent.py, server/migrations/versions/*, scam_image_mobile/lib/features/auth/**

ขั้นที่ 3 ตอบ 3 คำถามกับกฎที่เลือก โดยอ้างส่วนประกอบหรือส่วนต่อประสานที่มีจริง (6 คะแนน)

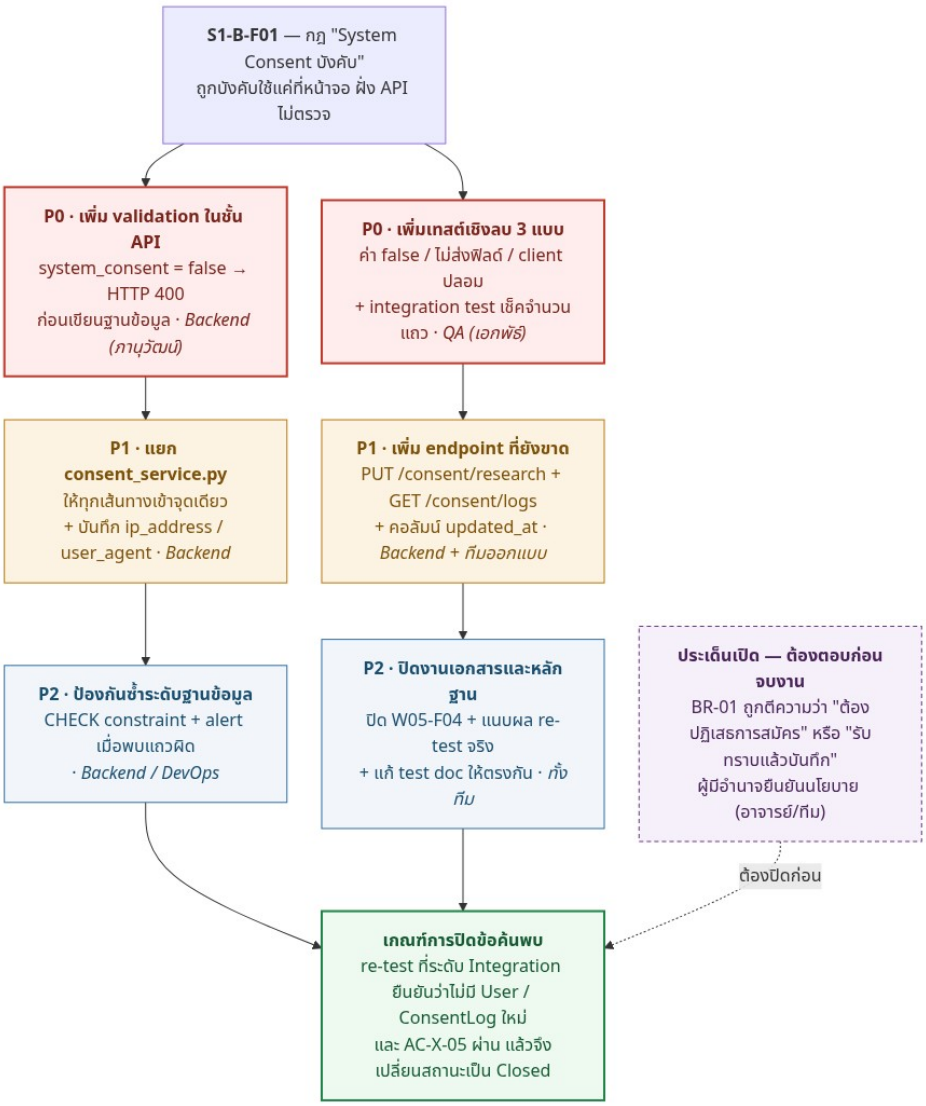
คำถาม	คำตอบและเหตุผล
1 ใครรับผิดชอบ	ชั้น API/บริการฝั่งเซิร์ฟเวอร์ คือ server/app/api/v1/auth.py เป็นกฎระดับข้อมูลที่ต้องบังคับได้ทุกทางเข้า (แอป ผู้ดูแลระบบ เครื่องมือทดสอบ) ไม่ใช่แค่หน้าจอสมัครสมาชิก
2 ข้อมูลส่งถึงครบไหม	ตอนนี้ยังไม่ครบ - ยังไม่มีช่องทางส่งหลักฐานว่าผู้ใช้ยอมรับ Terms จริง - ช่อง ip_address / user_agent ที่ออกแบบไว้เพื่อเป็นหลักฐาน PDPA ยังไม่ได้เขียน
3 ถ้าพัง จะรู้ได้ไหม	รู้ได้บางส่วน - การยิง POST /auth/register ด้วย system_consent=false จะได้ HTTP 201 และมีแถวใน consent_logs ตรวจจับได้ถ้ามี test case ระดับ API ที่ยืนยันเงื่อนไขนี้ ไม่มี test case ระดับ API ที่บังคับ 400 - บันทึก request/response ลงไฟล์ได้ ไม่มี API อ่านค่า consent กลับมา ผู้ทดสอบต้องต่อฐานข้อมูกตรง ซึ่งขัดกับหลัก least privilege (BR-06) และทำให้ผลทดสอบขึ้นกับสิทธิ์ของแต่ละคน ตรวจซ้ำไม่ได้

ขั้นที่ 4 เขียนข้อค้นพบ 1 ข้อ ครบ 4 ส่วน หรือถ้าไม่พบปัญหา ให้แสดงหลักฐานว่าตรวจแล้ว (4 คะแนน)

1 เอกสารหรือโค้ดเขียนว่าอะไร อยู่ตรงไหน	
2 ขัดกับข้อใด	1. FR-AUTH-01 AC-5 พฤติกรรมจริงคือ HTTP 201 + สร้างผู้ใช้ แทนที่จะเป็น HTTP 400 2. BR-01 กฎระบุว่า "สมัครต้องมี consent row" แต่ไม่ได้กำกับว่า consent row ที่บันทึกต้องเป็นคำตอบจริงของผู้ใช้ การรับ false ได้ทำให้ BR-01 ถูกใช้เป็นช่องบันทึกค่าที่ไม่ผ่านการยืนยัน 3. หลักการใน SRS บท 4 กฎธุรกิจต้องบังคับที่ชั้นที่ข้ามไม่ได้ การบังคับที่ UI ถือเป็นการออกแบบที่ข้ามได้ 4. FR-PDPA-01 AC-1 หน้าจอต้องเป็น Consent Screen ที่แยก System/Research ให้ผู้ใช้เลือก แต่ค่าที่ส่งไปเป็นค่าคงที่ จึงไม่ใช่การรับคำตอบจากผู้ใช้จริง 5. NFR-04 (ความปลอดภัย) การตรวจสอบข้อมูลและการกระทำต้องบังคับที่เซิร์ฟเวอร์ ไม่ควรผูกกับความน่าเชื่อถือของแอป

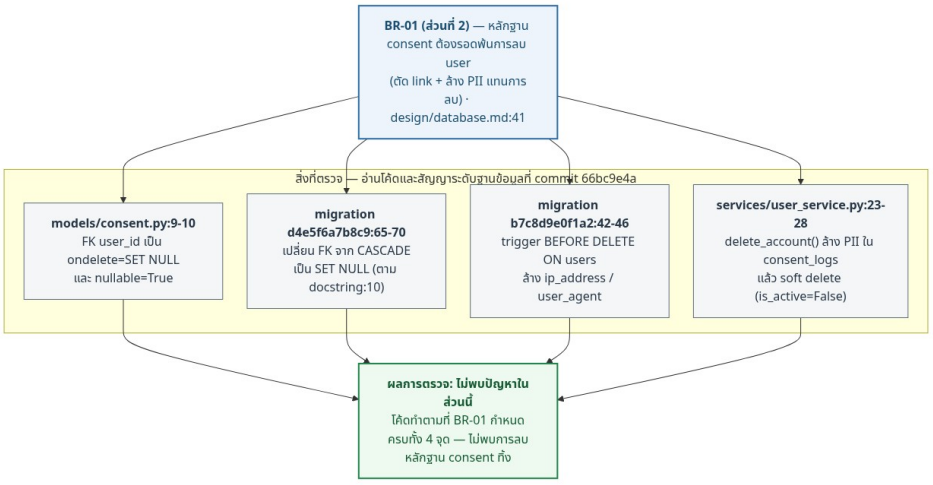
3 ผลต่อการทดสอบ	1. กรณีทดสอบเชิงลบที่เขียนตาม AC-5 จะ Fail และเป็น False Pass ถ้าเขียนผ่าน UI เพราะ UI บล็อกปุ่มเอง ทำให้เส้นทดสอบที่ "ผ่าน" ไม่ได้พิสูจน์ว่ากฎถูกบังคับที่ชั้นบริการ ต้องทดสอบผ่านการเรียก API ตรงเสมอสำหรับกฎระดับข้อมูล 2. AC บางข้อทดสอบไม่ได้เลย ต้องขึ้นสถานะ Not Testable ใน RTM FR-PDPA-01 AC-3 (ถอนยินยอม) และ AC-5 (ดู consent logs) ไม่มี endpoint ที่ระบุในเอกสาร ต้องเลื่อนเป็นเงื่อนไขของการปล่อยงานด้าน PDPA ไม่ใช่ปิดเคสว่า "ผ่าน" 3. เกณฑ์วัดความสำเร็จของเทสต์จะผิดความหมาย ถ้านับจากจำนวนเคสที่รันผ่าน จะได้ตัวเลขที่ดูดีแต่ไม่ได้พิสูจน์ว่าเงื่อนไข PDPA ถูกบังคับ ต้องวัดที่ "จำนวนเคสเชิงลบที่ถูกบังคับให้ถูกต้อง" แทน 4. การตรวจสอบหลักฐานทำไม่ได้ด้วย API ทำให้ตรวจซ้ำไม่ได้ ผู้ทดสอบต้องเข้าฐานข้อมูลตรง ซึ่งขัดกับ BR-06 (least privilege) และทำให้ผลทดสอบขึ้นกับสิทธิ์ของผู้รัน ไม่เหมาะกับการทำ regression 5. ผลกระทบต่อการทดสอบระดับระบบและ UAT สถานการณ์ "ผู้ใช้ปฏิเสธเงื่อนไขแล้วสมัครได้" จะผ่านในระบบ ทำให้ผล UAT ด้าน PDPA ที่ได้ไม่สะท้อนพฤติกรรมที่ผู้ใช้จริงจะเจอ และถ้าภายหลังบังคับใช้จริง ระบบจะต้องเปลี่ยนพฤติกรรม ซึ่งกระทบผู้ใช้เดิมที่ลงทะเบียนไว้แล้ว

4 ข้อเสนอ



หรือ หลักฐานว่าไม่พบปัญหา

ตำแหน่งโค้ด / ผลการเรียก API ตรง (แนบภาพ):



ขั้นที่ 5 เขียน Entry 2 ข้อ และ Exit 2 ข้อ สำหรับการทดสอบ feature นี้ต้องวัดได้ (4 คะแนน)

Entry	Exit
1. Baseline ถูกตรึงและบันทึกไว้ก่อนเริ่ม โค้ด main@66bc9e4a และ SRS v1.1 (SHA-256 99bb8d50...cd40a) พร้อมสภาพแวดล้อมที่ระบุรุ่นชัดเจน (PostgreSQL 15, Redis 7, migration ที่ alembic upgrade head) และบันทึกผลของคำสั่งเตรียมฐานข้อมูลไว้ในโฟลเดอร์ evidence 2. ชุดข้อมูลและเครื่องมือพร้อม บัญชีทดสอบอย่างน้อย 2 บัญชี (ยินยอมใช้งานวิจัย = true / false) payload register ที่ปรับค่า consent ได้ สคริปต์เก็บ request/response และคำสั่ง SQL แบบ read-only สำหรับนับแถว consent_logs ก่อน–หลัง เกณฑ์วัดเวลาตอบสนองตาม NFR-01 ถูกเตรียมไว้	1. เคสเชิงลบของ System Consent ผ่านครบ 3 แบบ (ส่ง false, ไม่ส่งฟิลด์, เรียกข้าม client ด้วย payload ปลอม) โดยทุกเคสต้องได้ HTTP 400 พร้อมข้อความตาม AC-5 และตรวจฐานข้อมูลแล้วไม่มีผู้ใช้/แถว consent เพิ่ม เกณฑ์ผ่าน: Fail 0/3 และมีผลรันจริงพร้อม timestamp 2. วงจร consent ผ่านครบ 4/4 ข้อของ FR-PDPA-01 (บันทึกตอนสมัคร ถอน ยินยอม ดูประวัติ หลักฐานยังอยู่หลังลบบัญชี) และ coverage ของเส้นทาง consent ไม่ต่ำกว่า 80% ตาม NFR-09 โดยไม่มีข้อบกพร่องระดับ Blocker/Critical ค้าง และมีรายการ AC ที่ยังทำไม่ได้ระบุเป็น Not Testable พร้อมเหตุผล

ขั้นที่ 6 หน้าที่ของสมาชิกและการใช้ AI (1 คะแนน)

ชื่อ–สกุล	รหัส	ทำส่วนใด
นาย ภานุวัฒน์ ต๋าคำ	67543210044-3	ขั้นที่ 1 (เลือก feature/กฎ), ขั้นที่ 2 (ผังส่วนประกอบและทางเดินข้อมูล), ขั้นที่ 4 (ข้อค้นพบและข้อเสนอ), ขั้นที่ 5 (Entry/Exit), รวบรวมไฟล์ส่ง
นาย เอกพันธ์ ทศทิศ รังสรรค์	67543210050-0	ขั้นที่ 3 (ตรวจว่าข้อมูลส่งถึงครบและมีจุดตรวจจริงหรือไม่), ตรวจหลักฐาน/เลขบรรทัดที่อ้างอิงทั้งหมด, peer review ก่อนส่ง

ใช้ **AI** หรือไม่ เพื่ออะไร	ใช้ AI เพื่อค้นหาตำแหน่งโค้ดและเลขบรรทัดที่เกี่ยวข้อง และร่างคำตอบ โดยกำหนดให้ยึด baseline ที่ตรึงไว้และห้ามสร้างผลการทดสอบที่ไม่ได้รัน
ข้อเสนอที่รับ แก้ หรือปฏิเสธ	รับข้อเสนอให้ใช้หลักฐานเดิมของทีม (W05-CT-12/14/15/17 และ W05-F04/F05/F06) มาอ้างอิงซ้ำแทนการตรวจซ้ำ และรับการแยกข้อสรุปของ baseline main กับ develop ให้ชัดเจน แก้คำตอบเรื่องชั้นที่ตรวจกฎ เพราะร่างแรกระบุว่าหน้าจอเป็นผู้ตรวจ และแก้จนเหลือข้อสรุปว่าไม่มีชั้นใดตรวจจริงในขณะนี้ พร้อมระบุชั้นที่ควรเป็นผู้ตรวจ
ตรวจกับโค้ดหรือเอกสารใด	SRS v1.1 (main/Document/srs, SHA-256 99bb8d50…cd40a) · design/database.md · โค้ดที่ main@66bc9e4a: server/app/api/v1/auth.py, server/app/schemas/auth.py, server/app/models/consent.py, server/app/services/user_service.py, server/migrations/versions/*, scam_image_mobile/lib/features/auth/** · หลักฐานเดิม WEEKS/week-05/work/**